

Checklist técnico de cumplimiento

Sterclicks — Auditoría paso a paso para Claude Code

Instrucciones generales: revisar cada punto directamente en el repositorio del proyecto Sterclicks (CodeIgniter 4, hosting Hostinger). Para cada ítem, verificar el estado actual en el código, indicar si cumple, no cumple o no aplica, y en caso de no cumplir, proponer el cambio mínimo necesario. No asumir nada sin comprobarlo en el código real.

A. Autenticación y gestión de contraseñas

- Verificar que las contraseñas de usuario se almacenan con `password_hash()` (bcrypt/argon2) y nunca en texto plano, MD5 o SHA1 sin salt.
- Verificar que el login usa `password_verify()` y no comparaciones directas de string.
- Comprobar que existe límite de intentos de login (rate limiting) por IP y/o por usuario, con bloqueo temporal tras varios fallos.
- Revisar si hay política mínima de complejidad de contraseña en el registro.
- Comprobar mecanismo de recuperación de contraseña: token de un solo uso, con expiración corta (ej. 30-60 min), invalidado tras su uso.
- Evaluar viabilidad de añadir autenticación de doble factor (2FA) al menos para el panel de administración (TOTP con Google Authenticator/Authy).
- Verificar que las sesiones expiran tras un periodo de inactividad razonable y que el logout invalida la sesión en servidor, no solo en cliente.

B. Inyección SQL, XSS y CSRF

- Revisar todas las consultas a base de datos: deben usar Query Builder o consultas preparadas de CI4 (`$db->query()` con binding), nunca concatenación directa de variables de usuario en SQL.
- Buscar en el código cualquier uso de `$this->db->query()` con variables interpoladas directamente sin parámetros ("?" o bindings) — son candidatas a inyección SQL.
- Verificar que CSRF protection está activado globalmente en `app/Config/Filters.php` (csrf en el array 'before' de todos los formularios que modifican datos).
- Comprobar que todos los formularios POST/PUT/DELETE incluyen `csrf_field()`.
- Revisar que la salida de datos de usuario en las vistas usa `esc()` de CI4 para prevenir XSS (nombres, comentarios, campos de personalización de figuras, etc.).
- Verificar cabeceras de seguridad HTTP: Content-Security-Policy, X-Content-Type-Options: nosniff, X-Frame-Options: DENY o SAMEORIGIN, Referrer-Policy.
- Comprobar validación y sanitización de todos los inputs del formulario de personalización de producto y del checkout, tanto en cliente como en servidor.

C. HTTPS y configuración del entorno

- Verificar que TODO el sitio fuerza HTTPS (incluye redirección automática desde HTTP), no solo el checkout.

- Comprobar cabecera Strict-Transport-Security (HSTS) activa.
- Verificar que app/Config/App.php tiene forceGlobalSecureRequests = true.
- Comprobar que CI4 está en modo 'production' en el .env (no 'development') en el servidor real, para no exponer detalles de errores/debug a usuarios.
- Revisar que el archivo .env NO está accesible públicamente vía URL (comprobar con petición directa a /.env) y que está en .gitignore.
- Verificar que writable/ no contiene archivos sensibles accesibles públicamente y que sigue excluido de git (recurrente en este proyecto según historial).
- Comprobar cabeceras de versión de servidor/PHP ocultas (no exponer versión exacta en Server header).

D. RGPD — consentimiento y derechos de usuarios

- Confirmar que el sistema de consentimiento de marketing (ConsentController, marketing_consent, marketing_consent_log) está correctamente integrado: revisar que UserModel incluye 'consent_token' y 'marketing_consent' en \$allowedFields.
- Verificar que ningún envío de marketing se dispara sin comprobar marketing_consent = 1 en el momento del envío (no solo en el momento del registro).
- Comprobar que existe un mecanismo de baja (unsubscribe) funcional y accesible desde cualquier email comercial, no solo desde el panel.
- Revisar si existe un endpoint o proceso para atender solicitudes de acceso, rectificación, supresión y portabilidad de datos (derechos ARSULIPO), aunque sea manual vía email por ahora.
- Verificar que al eliminar una cuenta de usuario se eliminan o anonimizan realmente sus datos personales en todas las tablas relacionadas (pedidos, direcciones, logs), no solo en la tabla users.
- Comprobar el formulario de registro: checkbox de marketing NO premarcado, separado claramente de la aceptación de términos del servicio.
- Revisar el texto legal mostrado en registro/checkout: enlaces a Aviso Legal, Política de Privacidad y Condiciones Generales visibles antes de enviar el formulario.

E. Gestión de cookies

- Inventariar todas las cookies que se instalan actualmente (sesión CI4, analítica, terceros como Brevo tracking si aplica, redes sociales).
- Verificar si existe banner de consentimiento de cookies. Si no existe, marcarlo como crítico.
- Si existe, comprobar que el botón 'Rechazar' es igual de visible y accesible que 'Aceptar' (un desequilibrio visual es motivo frecuente de sanción AEPD).
- Comprobar que NINGUNA cookie no esencial (analítica, marketing) se instala antes de obtener consentimiento explícito.
- Verificar que existe forma fácil de revocar el consentimiento de cookies después de haberlo dado (no solo borrando cookies del navegador manualmente).

F. Sistema de copias de seguridad

- Confirmar que BackupService, RunBackup, BackupController y BackupModel están correctamente ubicados según la estructura de CI4 (Libraries, Commands, Controllers, Models).
- Verificar que composer.json incluye aws/aws-sdk-php instalado.
- Comprobar que las variables backup.* están definidas en .env con valores reales (no los placeholders de ejemplo).
- Verificar que backup.encryptionKey NO está en el repositorio Git bajo ningún concepto (revisar historial de commits también, no solo el estado actual).
- Confirmar que las rutas admin/backups/* están protegidas por un filtro de autenticación de administrador real (no solo comentado como sugerencia en el código).
- Ejecutar (o simular) el comando 'php spark backup:run' en un entorno de prueba y verificar que el registro en la tabla backups queda en estado 'ok' con checksum calculado.
- Verificar que el cron job está configurado en hPanel de Hostinger con la ruta absoluta correcta al ejecutable PHP y al archivo spark.
- Comprobar que la política de retención (backup.retentionDays) borra efectivamente los backups caducados tanto en B2 como en la tabla local.

G. Pagos y logística

- Revisar el flujo de checkout completo: confirmar que el número de tarjeta nunca pasa por un endpoint propio de Sterclicks (debe ir directo del navegador a la pasarela, vía iframe/redirect/tokenización).
- Verificar que no se guardan datos de tarjeta en logs de aplicación ni en la base de datos (buscar 'card', 'cvv', 'pan' en el código y en migraciones).
- Comprobar que la integración con Packlink PRO (si ya está en producción) transmite solo los datos necesarios para el envío (nombre, dirección), no datos de cuenta o pago.

H. Información al consumidor en el checkout

- Verificar que antes de pagar se muestra: precio total con impuestos, gastos de envío desglosados, y plazo de entrega estimado.
- Comprobar que existe un aviso explícito de exclusión del derecho de desistimiento para productos personalizados (art. 103.c TRLGDCU), visible antes de confirmar el pedido, no solo en las condiciones generales.
- Verificar que se envía email de confirmación de pedido automático con el detalle completo (referencia, productos, precio, dirección de envío).
- Comprobar si existe enlace a la plataforma ODR de la UE en el footer o en la página de contacto/condiciones.

I. Logs y trazabilidad

- Verificar que existe log de accesos al panel de administración (quién, cuándo, desde qué IP).
- Comprobar que los logs de aplicación (app/Config/Logger.php) no registran datos personales sensibles en texto plano innecesariamente (contraseñas, tokens completos).
- Revisar rotación/retención de logs: no deben crecer indefinidamente ni conservarse más tiempo del necesario.

Formato de salida esperado

Para cada sección (A–I), generar una tabla o lista con: ítem revisado, estado (Cumple / No cumple / Parcial / No aplica), archivo(s) afectado(s), y acción recomendada si no cumple. Priorizar como críticos los puntos de las secciones B (inyección SQL/XSS/CSRF), C (HTTPS/.env expuesto) y A (contraseñas en texto plano), ya que son los de mayor riesgo inmediato.

Documento de trabajo interno para revisión técnica con Claude Code. No sustituye una auditoría de seguridad profesional ni asesoramiento legal especializado.